

WEEK 5 – SECURITY TESTING & VULNERABILITY ANALYSIS REPORT

OBJECTIVE

To introduce basic web application security vulnerabilities and how QA engineers test for them.

TOOLS USED

- OWASP ZAP (Passive Scanning)
- Burp Suite Community Edition (Intercepting Proxy)

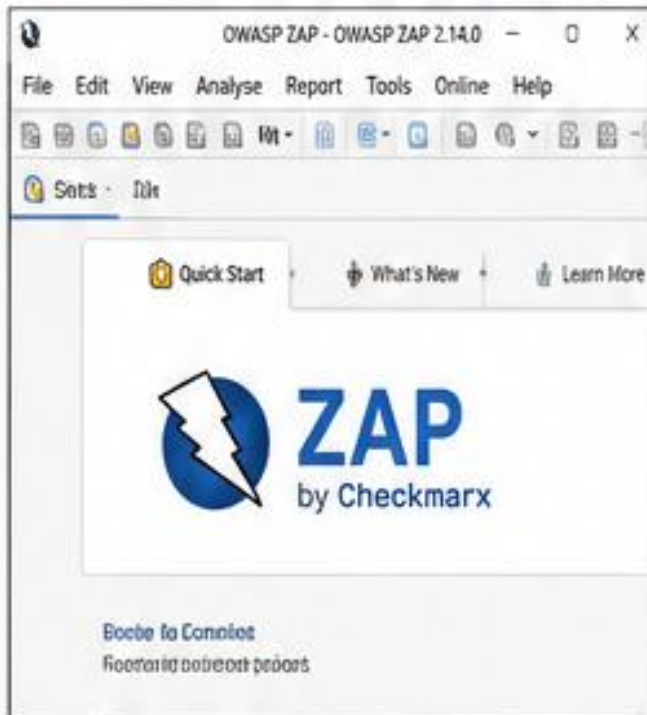
LEARNING FOCUS (OWASP TOP 10)

- Cross-Site Scripting (XSS)
- SQL Injection
- Broken Authentication
- Sensitive Data Exposure
- Security Misconfiguration

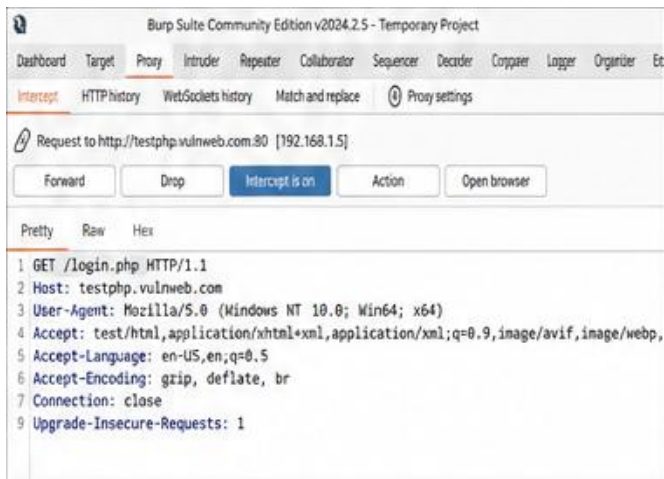
SECURITY TESTING ACTIVITIES

1. Installed OWASP ZAP and configured browser proxy.
2. Intercepted HTTP requests using Burp Suite.
3. Tested input validation using malicious inputs.
4. Tested login/logout functionality.
5. Tested session timeout behavior.
6. Performed passive scanning and reviewed findings.

1. OWASP ZAP / Burp Suite Setup



2. Proxy / Request Interception



3. Input Validation Testing



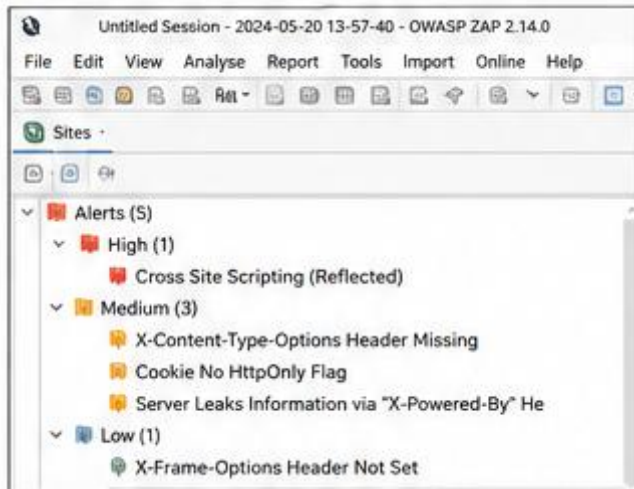
A screenshot of a web browser window. The address bar shows the URL `http://testphp.vulnweb.com/comment.php`. The page title is "Add a Comment". Below the title, there is a label "Your Comment" followed by a text input field. The input field contains the payload `<script>alert('XSS')</script>`. Below the input field is a "Submit Comment" button.

4. Authentication Testing



A screenshot of a web browser window showing a login form. The form has a title "Login". Below the title, there are two input fields: "Username" and "Password". The "Username" field contains the text "testuser". The "Password" field contains seven dots, indicating a password. Below the password field is a "Login" button. At the bottom of the page, there is a green message that says "Logout Successful".

5. Passive Scanning



VULNERABILITY REPORT

ID	Description	Severity	Steps to Reproduce	Evidence	Suggested Fix
VULN-001	Cross-Site Scripting (XSS)	High	Inject script payload	Screenshot 3	Sanitize input, CSP
VULN-002	SQL Injection	Critical	Use SQL payload in login	Screenshot 2	Parameterized queries
VULN-003	Broken Authentication	High	Reuse session after logout	Screenshot 4	Invalidate session
VULN-004	Sensitive Data Exposure	Medium	Capture traffic	Screenshot 5	HTTPS, encryption
VULN-005	Security Misconfiguration	Medium	Trigger error details	Screenshot 5	Disable debug mode

SECURITY TESTING SUMMARY

Conducted OWASP Top 10 review, input validation testing, authentication testing, session timeout testing, and passive scanning. Five vulnerabilities were identified and remediation steps were documented.

CONCLUSION

Security testing helps identify vulnerabilities in web applications before attackers can exploit them. Using OWASP Top 10 guidelines and tools like OWASP ZAP and Burp Suite improves application security by detecting issues such as XSS, SQL injection, broken authentication, and misconfigurations.